Sécurité des systèmes informatiques

Dispositifs de protection

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

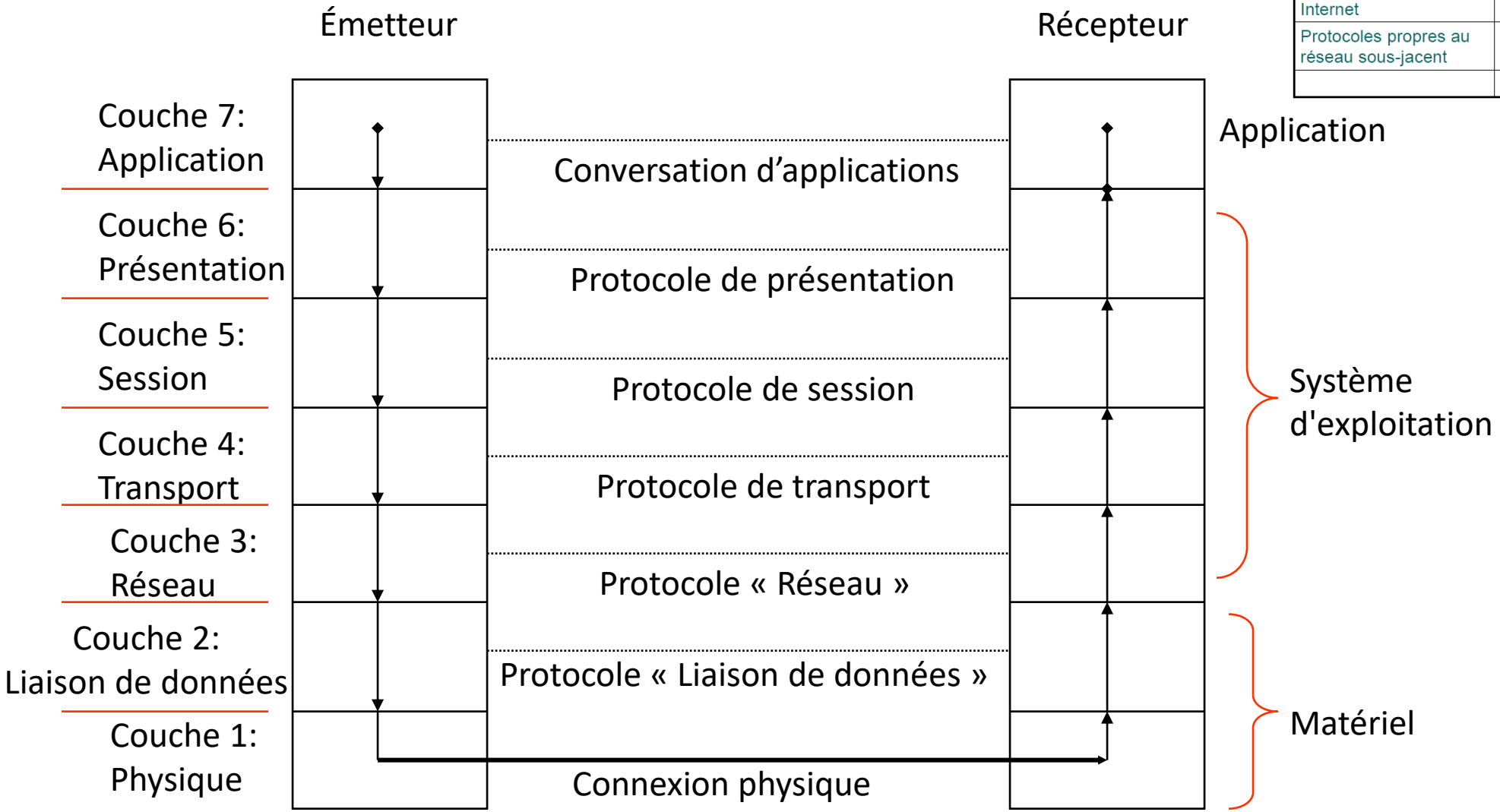
- Dispositifs de protection
- Technologies réseau
- Conception sécuritaire des réseaux informatiques

Pourquoi des dispositifs de protection?

- Pas toutes les applications conçues et développées avec la sécurité en perspective
  - Le réseau doit fournir une protection
- Un réseau avec une faible sécurité est une invitation aux pirates
- Aspects de la construction d'un réseau sécurisé
  - **Dispositifs** de protection du réseau
  - **Technologies** réseau
  - **Conception** du réseau lui-même

Le modèle de réseau OSI

TCP/IP	Hybride	OSI
Applications	Applications	Applications
		Présentation
		Session
Transport	Transport	Transport
Internet	Internet	Réseau
Protocoles propres au réseau sous-jacent	Liaison de données	Liaison de données
	Physique	Physique

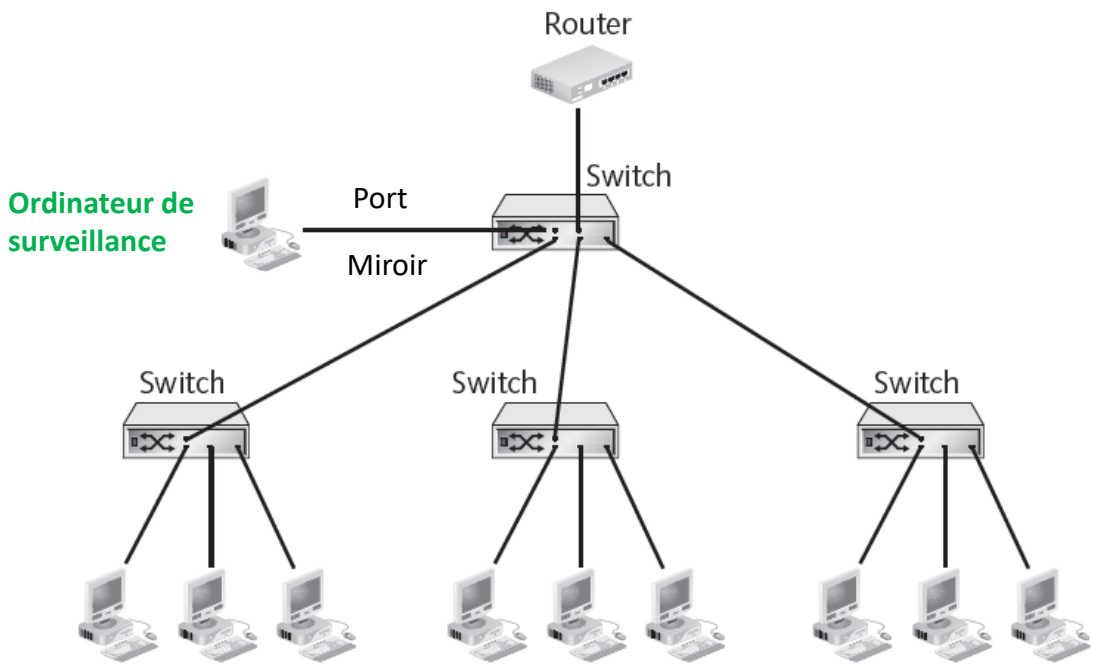


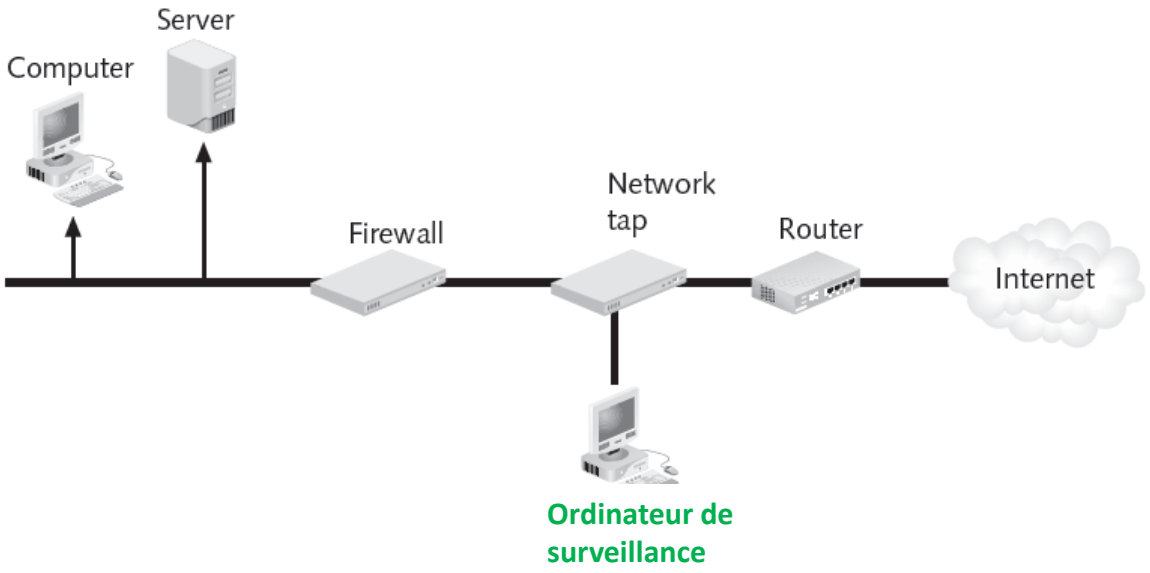
Dispositifs réseau

- **Concentrateur** (*Hub*)
  - Connecte plusieurs dispositifs du réseau local
  - **Couche 1** du modèle OSI
- **Commutateur** (*Switch*)
  - Connecte plusieurs segments du réseau
  - **Couche 2** du modèle OSI
  - Utilise l'adresse MAC pour identifier une machine sur le réseau
- **Routeur** (*Router*)
  - Routage des paquets entre les différents réseaux
  - **Couche 3** du modèle OSI
  - Peut filtrer un type spécifique du trafic réseau (routeur filtrant)
- **Répartiteur de charge** (*load balancer*)
  - Logiciel ou matériel

Dispositifs réseau (suite)

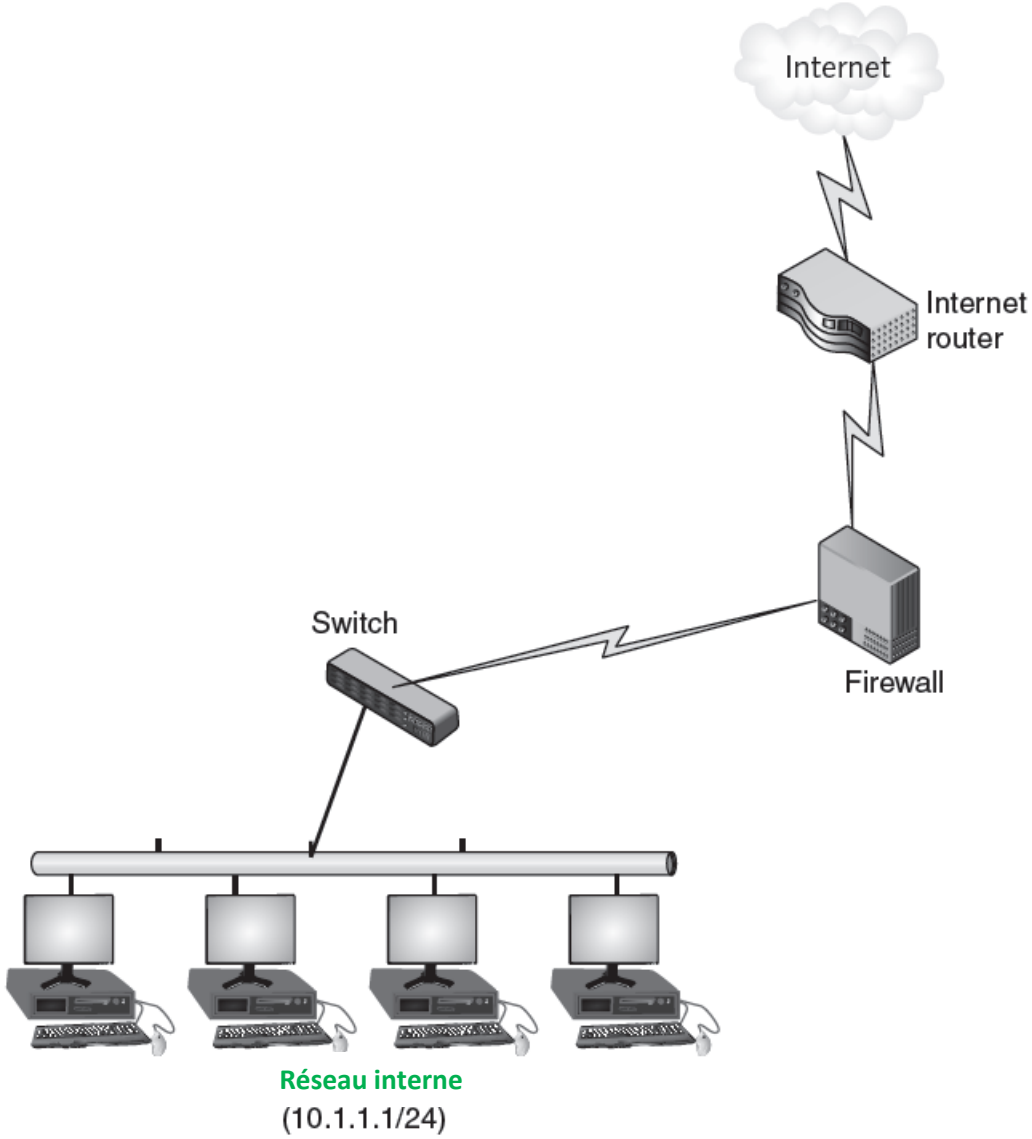
- L'administrateur réseau doit être capable de surveiller le trafic réseau





Pare-feu

- *Firewall*
- Inspecter les paquets pour les accepter ou les rejeter
- Logiciel ou matériel
- Habituellement situé à l'extérieur du périmètre sécuritaire du réseau
- Actions sur les paquets en transit
  - Autoriser (*allow*)
  - Bloquer (*deny*)
  - Demander l'action appropriée



Pare-feu (suite)

- Règles de filtrage
  - Ensemble de règles (*rules*) pour contrôler les actions du pare-feu
  - Exemple d'une règle

Description de la règle	Explication	Filtrage
Adresse IP source = tout	L'adresse IP source d'un ordinateur quelconque sur Internet	Car l'adresse IP d'un client du serveur Web ne peut pas être connue au préalable, cette règle autorise un paquet provenant de n'importe quelle adresse d'accéder au réseau
Adresse IP destination = Adresse IP interne	L'adresse destination est l'adresse IP d'un serveur Web public dans le réseau interne	Cette règle autorise le passage des paquets destinés au serveur Web public mais bloque les paquets avec une adresse destination arbitraire ou invalide
Port = 80	Indique quel port est ouvert pour accepter le paquet	Aucun autre port n'est ouvert sauf si c'est clairement indiqué

  - Dernière règle: **BLOQUER TOUT**
- Ces règles peuvent être des paramètres de haut niveau

Pare-feu (suite)

- **Filtrage simple** de paquets (***stateless*** *packet filtering*)
  - Inspecte les paquets, un par un, pour appliquer l'action appropriée
  - Liste de contrôle pour le filtrage séquentiel en **entrée**
    - Adresse IP source
    - Fanions TCP
    - Numéros de ports
    - Message ICMP
    - Etc.
  - Liste de contrôle pour le filtrage séquentiel en **sortie**
    - …

1. Si adresse IP d'origine = 10.*.*.*, REJETER [gamme d'adresses IP privées]
2. Si adresse IP d'origine = 172.16.*.* à 172.31.*.*, REJETER [gamme d'adresses IP privées]
3. Si adresse IP d'origine = 192.168.*.*, REJETER [gamme d'adresses IP privées]
4. Si adresse IP d'origine = 60.47.*.*, REJETER [gamme d'adresses IP internes]
5. Si adresse IP d'origine = 1.2.3.4, REJETER [adresse de liste noire]
6. Si TCP SYN=1 et FIN=1, REJETER [paquet d'attaque modifié]
7. Si adresse IP de destination = 60.47.3.9 et port de destination TCP = 80 ou 443, ACCEPTER [connexion à un serveur Web public]
8. Si TCP SYN=1 et ACK=0, REJETER [tentative d'ouverture de connexion depuis l'extérieur]
9. Si port de destination TCP = 20, REJETER [connexion de données FTP]
10. Si port de destination TCP = 21, REJETER [connexion de contrôle FTP]
11. Si port de destination TCP = 23, REJETER [connexion de données Telnet]
12. Si port de destination TCP = 135 à 139, REJETER [connexion NetBIOS pour clients]
13. Si port de destination TCP = 513, REJETER [rlogin UNIX sans mot de passe]
14. Si port de destination TCP = 514, REJETER [shell de démarrage rsh UNIX sans enregistrement]
15. Si port de destination TCP = 22, REJETER [SSH pour enregistrement sécurisé, mais certaines versions peu sûres]
16. Si port de destination UDP = 69, REJETER [protocole TFTP ; enregistrement inutile]
17. Si type ICMP = 0, ACCEPTER [accepter les messages de réponse d'écho entrants]
18. BLOQUER TOUT

Exemple de liste de filtrage en entrée

1. Si adresse IP d'origine = 10.*.*.*, REJETER [gamme d'adresses IP privées]
2. Si adresse IP d'origine = 172.16.*.* à 172.31.*.*, REJETER [gamme d'adresses IP privées]
3. Si adresse IP d'origine = 192.168.*.*, REJETER [gamme d'adresses IP privées]
4. Si adresse IP d'origine NON = 60.47.*.*, REJETER [en dehors de la gamme d'adresses internes]
5. Si type ICMP = 8, ACCEPTER [accepter les messages d'écho sortants]
6. Si protocole = ICMP, REJETER [rejeter tous les autres messages ICMP sortants]
7. Si TCP RST = 1, REJETER [ne pas accepter les segments RST sortants, servant au sondage du réseau par les attaquants]
8. Si adresse IP d'origine = 60.47.3.9 et port d'origine TCP = 80 ou 443, AUTORISER [serveur Web public]
9. Si port d'origine TCP = 0 à 49151, REJETER [ports réservés et enregistrés]
10. Si port d'origine UDP = 0 à 49151, REJETER [ports réservés et enregistrés]
11. Si port d'origine TCP = 49152 à 65536, ACCEPTER [autoriser les connexions sortantes]
12. Si port d'origine TCP = 49152 à 65536, ACCEPTER [autoriser les connexions sortantes]
13. BLOQUER TOUT

Exemple de liste de filtrage en sortie

Pare-feu (suite)

- **Filtrage dynamique** (***stateful*** *inspection*)
  - Enregistrement des deux adresses IP et numéros de ports dans une table d'états lors de l'ouverture d'une connexion
  - Acceptation de tous les paquets appartenant aux connexions enregistrées avec un minimum d'inspection

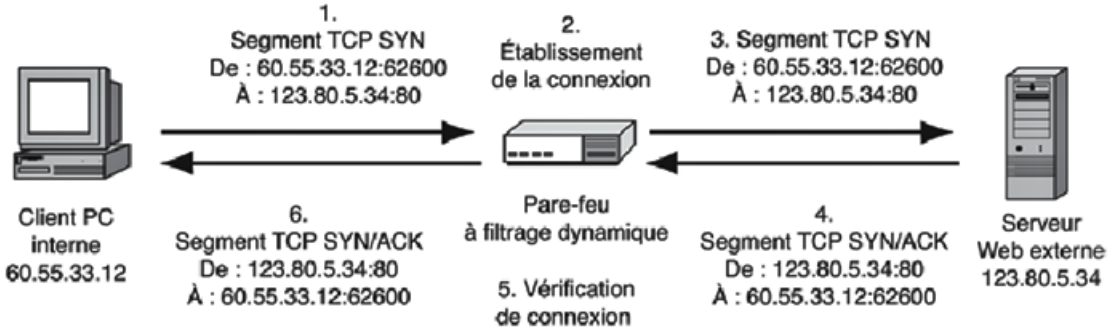


Table de connexion

Type	Adresse IP interne	Numéro de port interne	Adresse IP externe	Numéro de port externe	État
TCP	60.55.33.12	62600	123.80.5.34	80	OK
UDP	60.55.33.12	63206	1.8.33.4	69	OK

Pare-feu (suite)

- **Filtrage dynamique** (suite)
  - Liste de contrôle (inspection dynamique)
    - Comme dans le cas statique, mais pour des paquets applicatifs
  - Accepter ou bloquer les paquets en provenance d'applications spécifiques
  - Pas besoin de règles spécifiques pour bloquer les paquets de balayage de ports ne faisant partie d'aucune connexion enregistrée

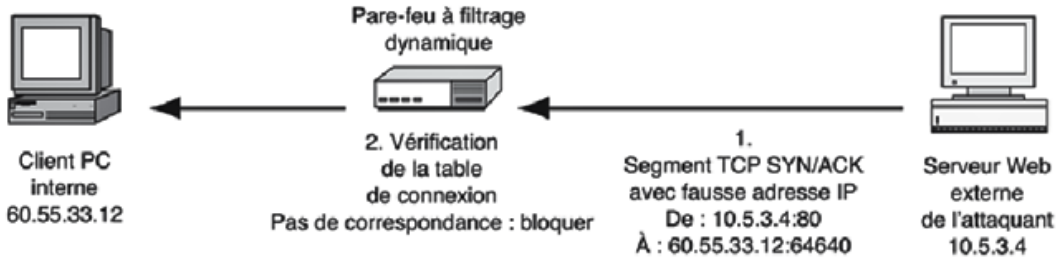
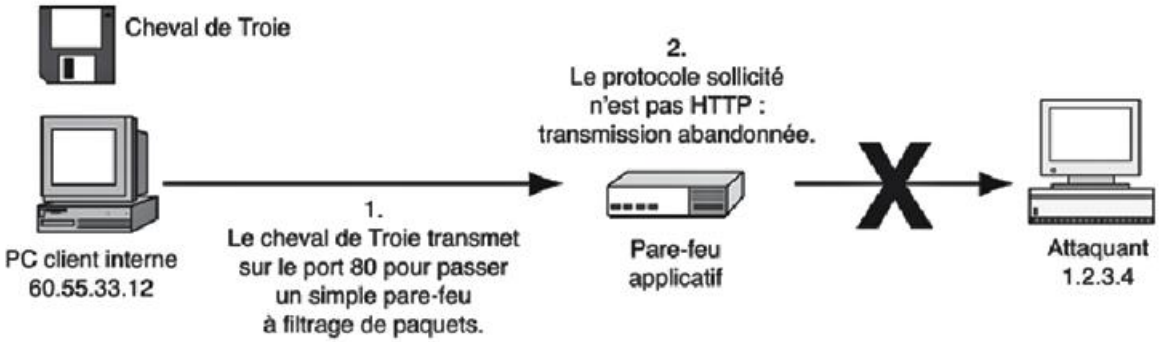


Table de connexion

Type	Adresse IP interne	Numéro de port interne	Adresse IP externe	Numéro de port externe	État
TCP	60.55.33.12	62600	123.80.5.34	80	OK
UDP	60.55.33.12	63206	222.8.33.4	69	OK

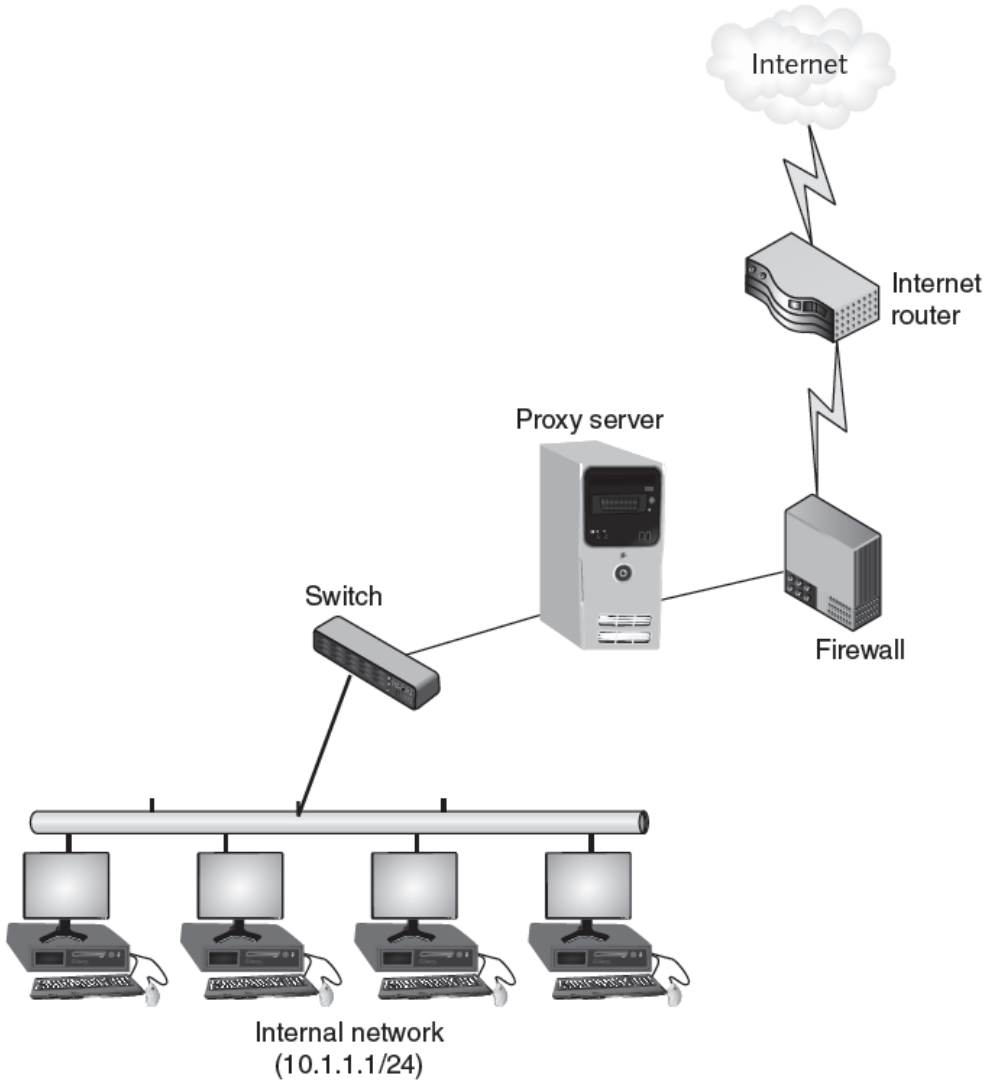
Pare-feu (suite)

- Pare-feu applicatif (Web)
  - Inspecte en profondeur les paquets qui acheminent du trafic HTTP
    - Navigateurs Web
    - FTP
    - Telnet
  - Peut être logiciel ou matériel, côté client ou serveur
  - Peut bloquer des sites spécifiques ou des attaques avec signature bien connue
  - Peut bloquer les attaques de type XSS et de type injection SQL



Serveur mandataire

- *Proxy*
- Un serveur ou une application qui intercepte et traite les demandes des utilisateurs internes
- Si une page Web a été précédemment demandée
  - Une copie de cette page peut se retrouver dans le **cache** du serveur proxy
- Sinon, le serveur proxy demandera la page Web en utilisant son adresse IP

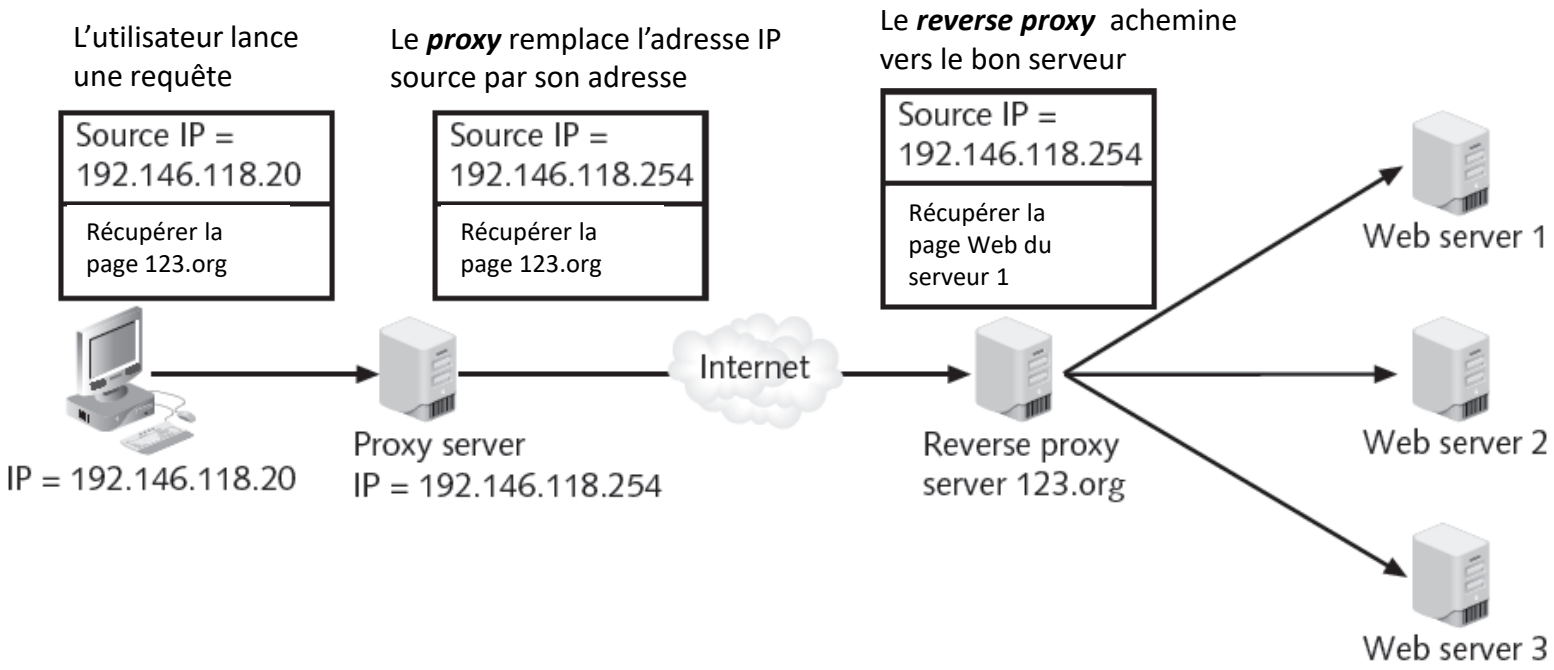


Serveur mandataire (suite)

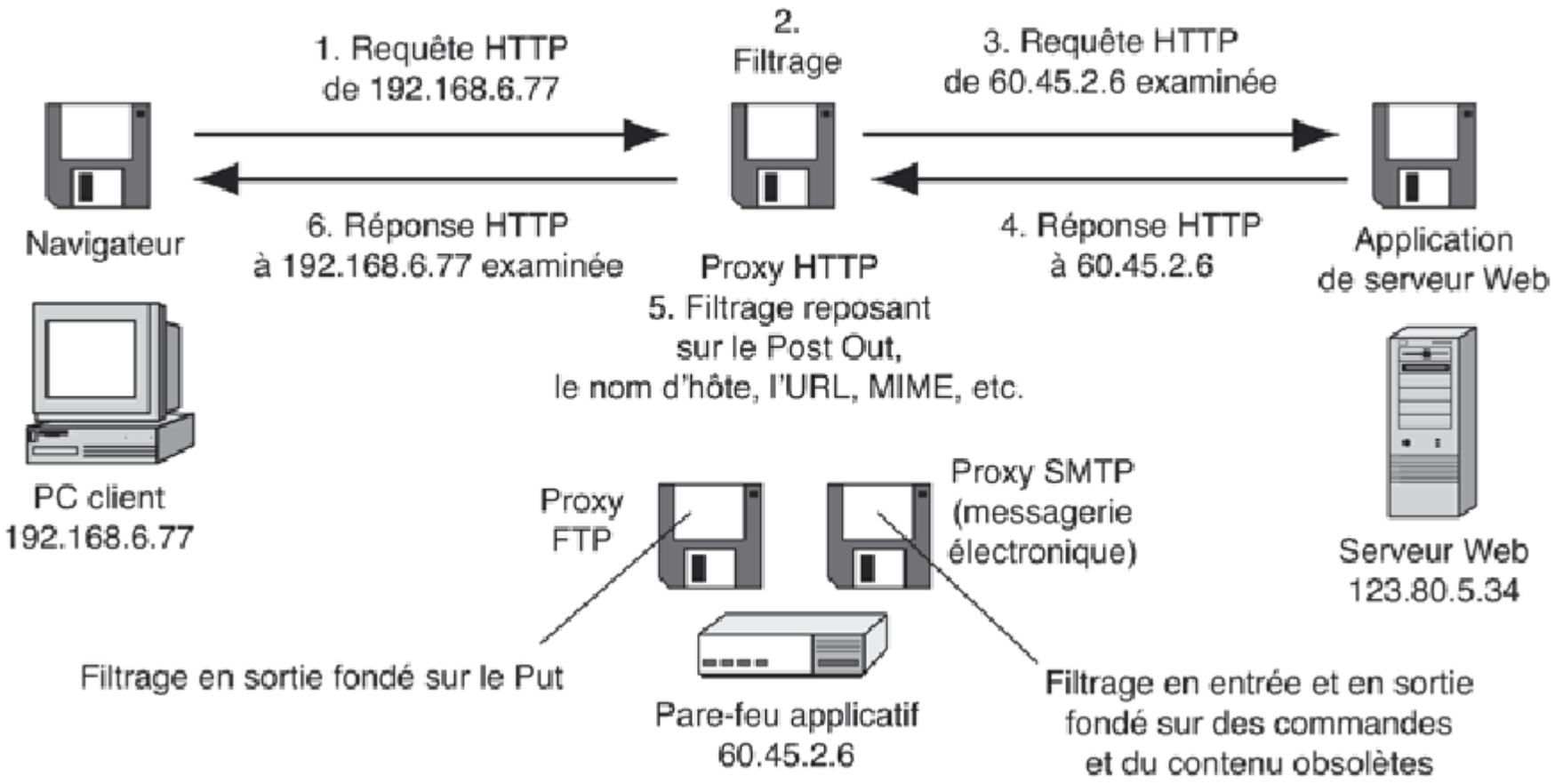
- Avantages
  - Améliorer les temps de réponse (utilisation du **cache**)
  - Réduire les coûts (la bande passante nécessaire)
  - Améliorer la gestion de la sécurité
    - Bloquer des sites/pages Web spécifiques
  - Renforcer la sécurité
    - Intercepter les maliciels (*malwares*)
    - Cacher les adresses IP des utilisateurs internes

Serveur mandataire (suite)

- *Reverse proxy*
  - Servir les utilisateurs externes
  - Diriger les requêtes provenant de l'extérieur vers le bon serveur
  - Seulement l'adresse IP du *reverse proxy* est visible de l'extérieur
    - Les adresses IP internes sont cachées



Serveur mandataire (suite)



Système de détection d'intrusion

- *Intrusion detection system* (IDS)
- Système qui permet de détecter et de signaler les intrusions
- Principe
  - **Observer:** capteurs, fichiers de journaux applicatifs, fichiers de traces système, paquets réseau, etc.
  - **Analyser:** identification d'indices d'attaques
    - Recherche de signes de reconnaissance: signature connue
      - Exemple: succession de paquets spécifiques
    - Recherche d'anomalies: recherche de comportements suspects
  - **Agir:** signal d'alarme, envoi de courriels, actions dynamiques
    - Exemple: demander au pare-feu de bloquer les entrées du réseau

Système de détection d'intrusion (suite)

- Méthodologies de surveillance
  - Basée sur les anomalies (*anomaly-based monitoring*)
    - Comparer les comportements présents à une base d'activités normales
  - Basée sur la signature
    - Chercher des signatures d'attaques bien connues
  - Basée sur le comportement
    - Détecter les actions anormales des processus ou des programmes
    - Alerter l'utilisateur qui décide s'il souhaite autoriser ou bloquer l'activité
  - Basée sur des heuristiques
    - Utiliser des techniques basées sur les expériences passées

Système de détection d'intrusion (suite)

Méthodologie de surveillance	Détecte les applications de balayage de ports?	Commentaire
Basée sur les anomalies	Probablement	Seulement si une entrée dans la base d'anomalies a été créée pour l'application qui avait essayé auparavant de faire un balayage
Basée sur la signature	Probablement	Seulement si la signature du balayage par cette application a été créée auparavant
Basée sur le comportement	Probablement	Seulement si les actions de cette application sont différentes des autres applications
Basée sur des heuristiques	Oui	L'IDS est déclenché si n'importe quelle application essaye de balayer plusieurs ports

Système de détection d'intrusion (suite)

- Deux grandes familles distinctes d'IDS:
  - **NIDS** (*Network Based Intrusion Detection System*)
    - Assure la sécurité d'un réseau
  - **HIDS** (*Host Based Intrusion Detection System*)
    - Assure la sécurité d'une machine

Système de détection d'intrusion (suite)

- HIDS
  - Application logicielle qui détecte une attaque dès son apparition
  - Installé sur chaque machine qui requiert une protection
  - Surveille les appels et l'accès aux fichiers système
  - Reconnaît les modifications non autorisées au registre système
  - Surveille toutes les communications en entrée et en sortie
    - Détecte les activités anormales
  - Inconvénients
    - Ne peut pas surveiller le trafic qui ne parvient pas aux machines locales
    - Les données de journalisation sont stockées localement
    - Consommation élevée des ressources (possibilité de ralentissement du système)

Système de détection d'intrusion (suite)

- NIDS
  - Surveille les attaques sur le réseau
  - Capteurs installés sur les pare-feu et les routeurs
    - Collecte d'informations pour le NIDS
  - Un NIDS passif va seulement déclencher un signal d'alarme
  - Un NIDS actif va déclencher un signal d'alarme et exécuter des actions
    - Exemple d'action: filtrer l'adresse IP de l'intrus ou terminer la session TCP

Technique d'évaluation	Description
Vérification de la pile protocolaire (*Protocol stack verification*)	Certaines attaques utilisent des configurations de protocoles invalides (IP, TCP, UDP ou ICMP). La vérification de la pile protocolaire peut identifier des paquets invalides comme des paquets IP fragmentés
Vérification des protocoles applicatifs (*Application protocol verification*)	Certaines attaques essayent d'exploiter un comportement invalide des protocoles applicatifs ou une signature d'attaque bien connue (ex. *DNS poisoning*). Le NIDS essayera de vérifier les protocoles applicatifs pour détecter ces signatures caractéristiques
Création de journaux étendus	Un NIDS peut journaliser les évènements inhabituels pour les rendre disponibles aux autres systèmes de surveillance

Système de détection d'intrusion (suite)

- **Système de prévention d'intrusion** (*Network Intrusion Prevention System*, **NIPS**)
  - Similaire à un NIDS actif
  - Surveille le trafic réseau pour bloquer immédiatement toute attaque
  - Capteurs situés au niveau du pare-feu
- Appareils de sécurité **tout-en-un** (*All-in-one network security appliances*)
  - Dispositifs intégrés qui remplacent plusieurs dispositifs de sécurité
  - À combiner avec les dispositifs réseau traditionnels tels qu'un routeur
  - Avantage de l'approche
    - Les dispositifs réseau déjà inspectent tous les paquets entrants et sortants

Filtrage Web

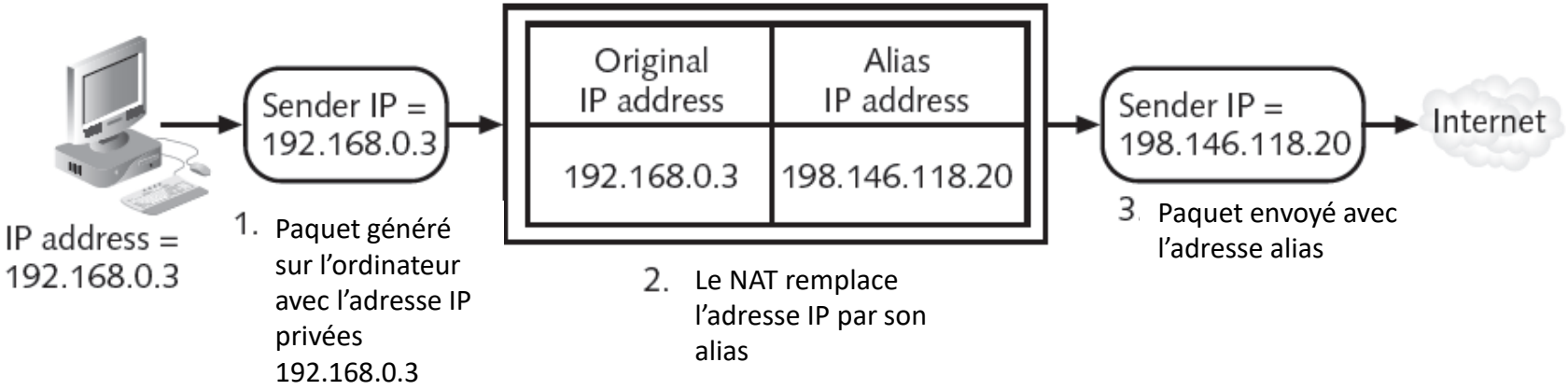
- Les pare-feu et IDS protègent les réseaux des attaques provenant de l'extérieur (Internet)
  - Les pirates essayeront donc de les contourner en utilisant des utilisateurs internes au réseau
    - Visite de sites Web malicieux
    - Installation de codes malicieux à partir des attachements des courriels
  - Pas besoin d'intrusion directe à travers le pare-feu
  - Les pare-feu applicatifs peuvent ne pas détecter ce genre d'attaques
- Filtrage Web
  - Peut bloquer les contenus malicieux en temps réel
  - Filtrage au niveau applicatif
- Exemple de trafic Web bloqué: adware, spyware, partage de fichiers pair à pair, exploits de type script, objets ActiveX, etc.

NAT

- *Network address translation* (NAT)
- Permet l'utilisation des adresses IP privées sur le réseau public (Internet)
  - Remplace une adresse IP privée par une adresse IP publique
- *Port address translation* (PAT)
  - Variante du NAT
    - Attribuer la même adresse IP aux paquets sortants, mais avec un numéro de port différent
- Adresses privées

Classe	Adresse de début	Adresse de fin
Classe A	10.0.0.0	10.255.255.255
Classe B	172.16.0.0	172.31.255.255
Classe C	192.168.0.0	192.168.255.255

NAT (suite)



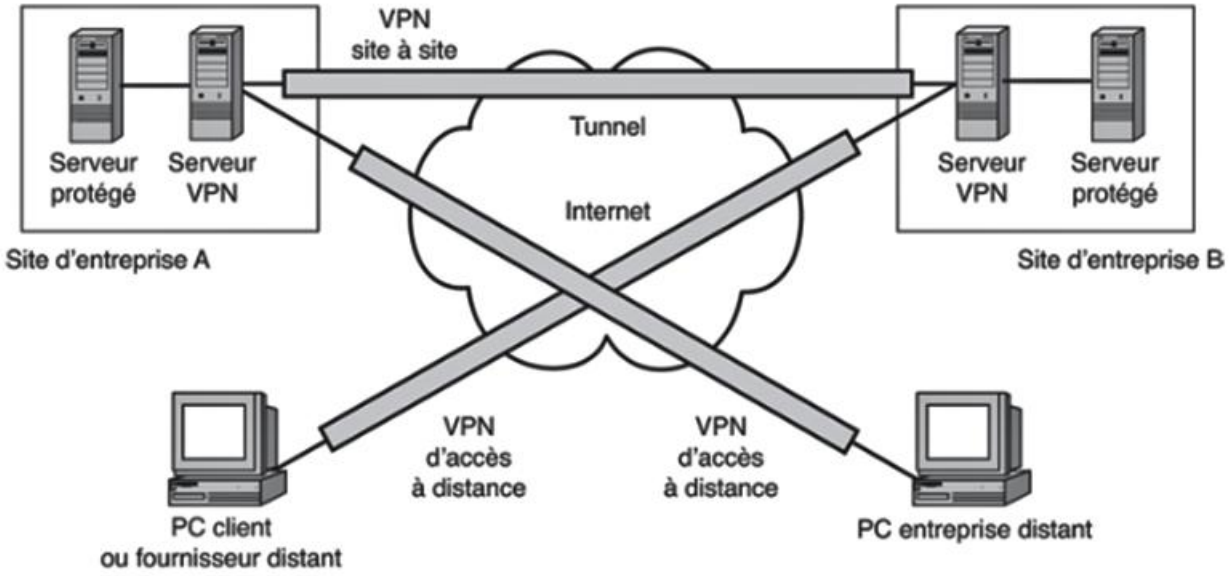
- Avantages
  - Masquer les adresses IP des machines internes
  - Permet à plusieurs machines de partager un nombre restreint d'adresses IP publiques

Réseau privé virtuel

- *Virtual private network* (VPN)
- Connexion de plusieurs sous-réseaux (et clients) de façon sécuritaire à travers un réseau intermédiaire non sécurisé
- Techniques
  - Tunneling
    - Permettre aux données, passant d'une extrémité du VPN à l'autre, d'être sécurisées (chiffrement)
    - Encapsulation des paquets: l'ancien paquet devient le message (nouvel en-tête)
  - Chiffrement
    - Le message est chiffré pour éviter l'interception ou la modification sur le réseau intermédiaire
  - Contrôle d'accès
    - Seuls les paquets provenant des clients ou des sous-réseaux autorisés sont réacheminés vers le réseau interne

Réseau privé virtuel (suite)

- Types de VPNs
  - Accès à distance
    - Connexion d'un utilisateur au réseau local
  - Site à site
    - Plusieurs sites (réseaux locaux) peuvent se connecter à d'autres sites en utilisant Internet



Réseau privé virtuel (suite)

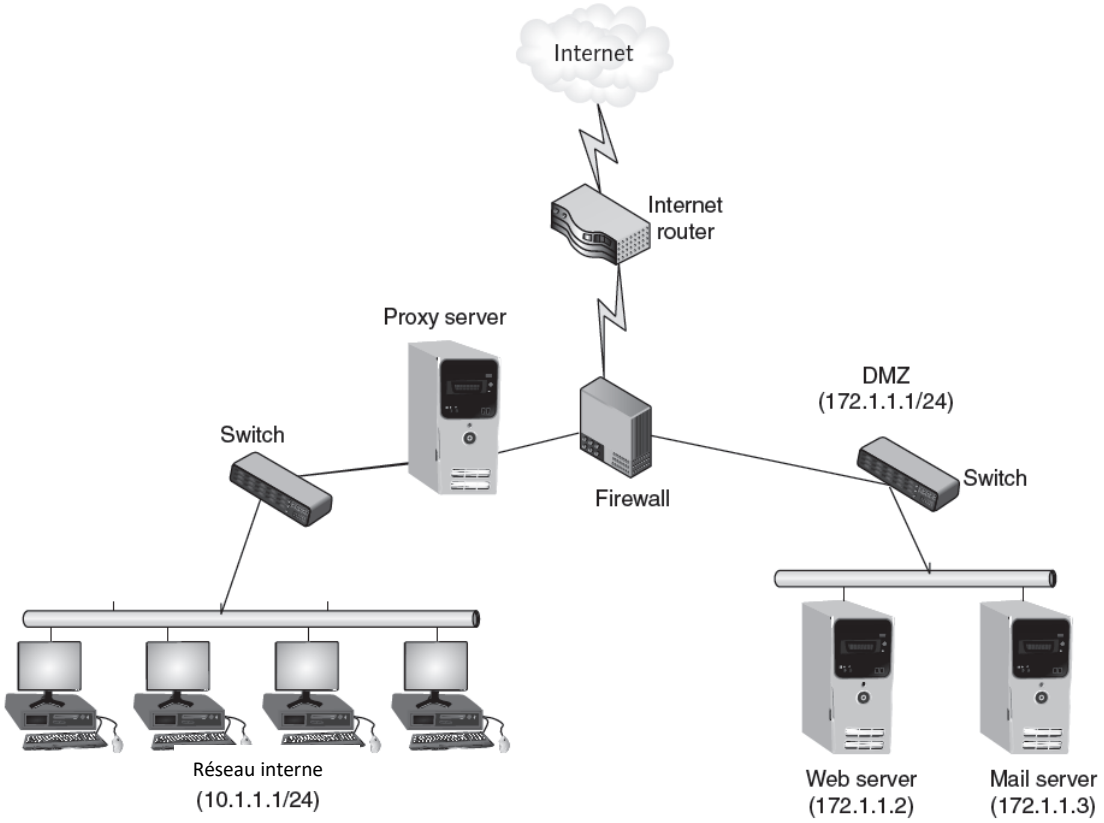
- Terminaux (*Endpoints*)
  - Utilisés pour la transmission des données
  - Peut être un logiciel sur un ordinateur local
  - Peut être matériel (concentrateur VPN)
  - Peut être intégré dans un autre dispositif réseau
- Un VPN peut être logiciel ou matériel
  - Un VPN matériel possède, généralement, un meilleur niveau de sécurité
  - Un VPN logiciel possède une meilleure flexibilité dans la gestion du trafic réseau

Conception sécuritaire du réseau

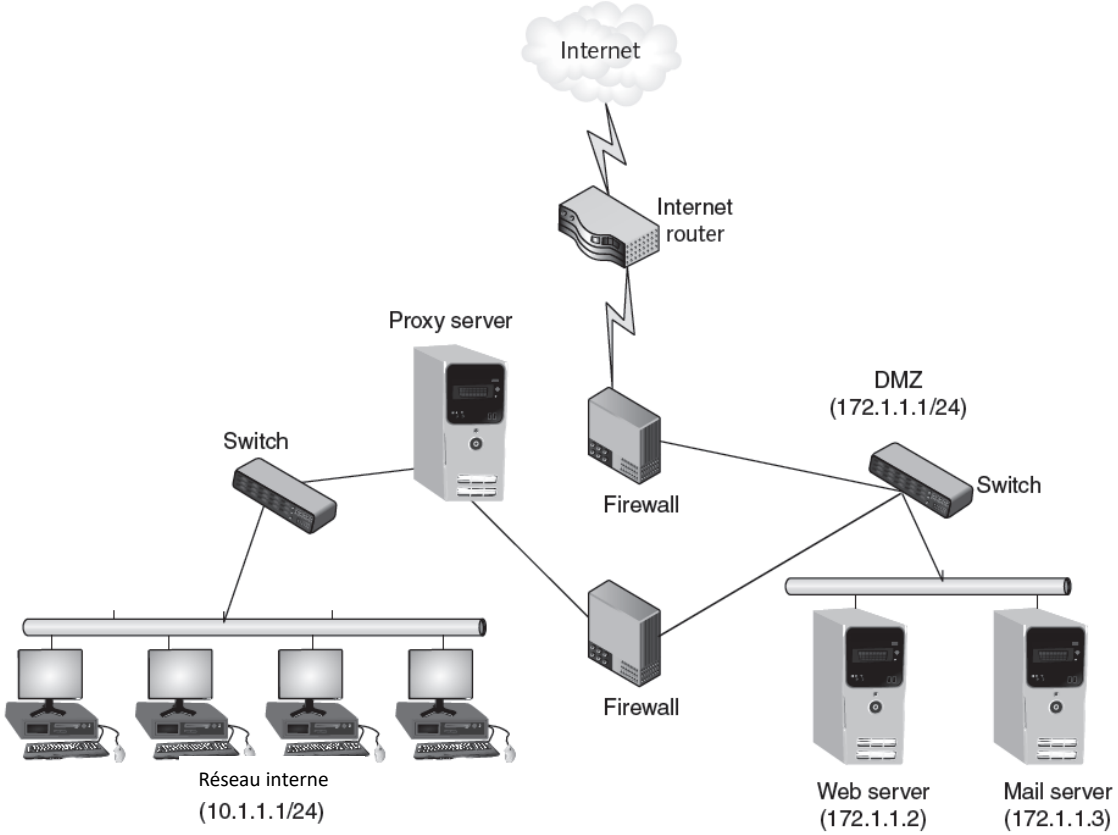
- Bastionnage du réseau
  - Bloquer le trafic non pertinent
  - Segmentation
    - Utilisation de routeurs, passerelles et serveurs proxy pour
      - Cacher les adresses IP internes
      - Protéger les serveurs et services critiques
  - Défense en profondeur
    - Principe de l' oignon
    - Gérer un contexte différent à chaque niveau
- Éléments d'une conception sécuritaire
  - Zone démilitarisée (DMZ)
  - Subnetting
  - Virtual LANs
  - Accès distant

Zone démilitarisée

- *Demilitarized Zone* (DMZ)
- Un réseau séparé situé à l'extérieur du périmètre sécurisé
- Les utilisateurs externes peuvent accéder à la DMZ, mais pas au réseau sécurisé



DMZ avec un pare-feu



DMZ avec deux pare-feu

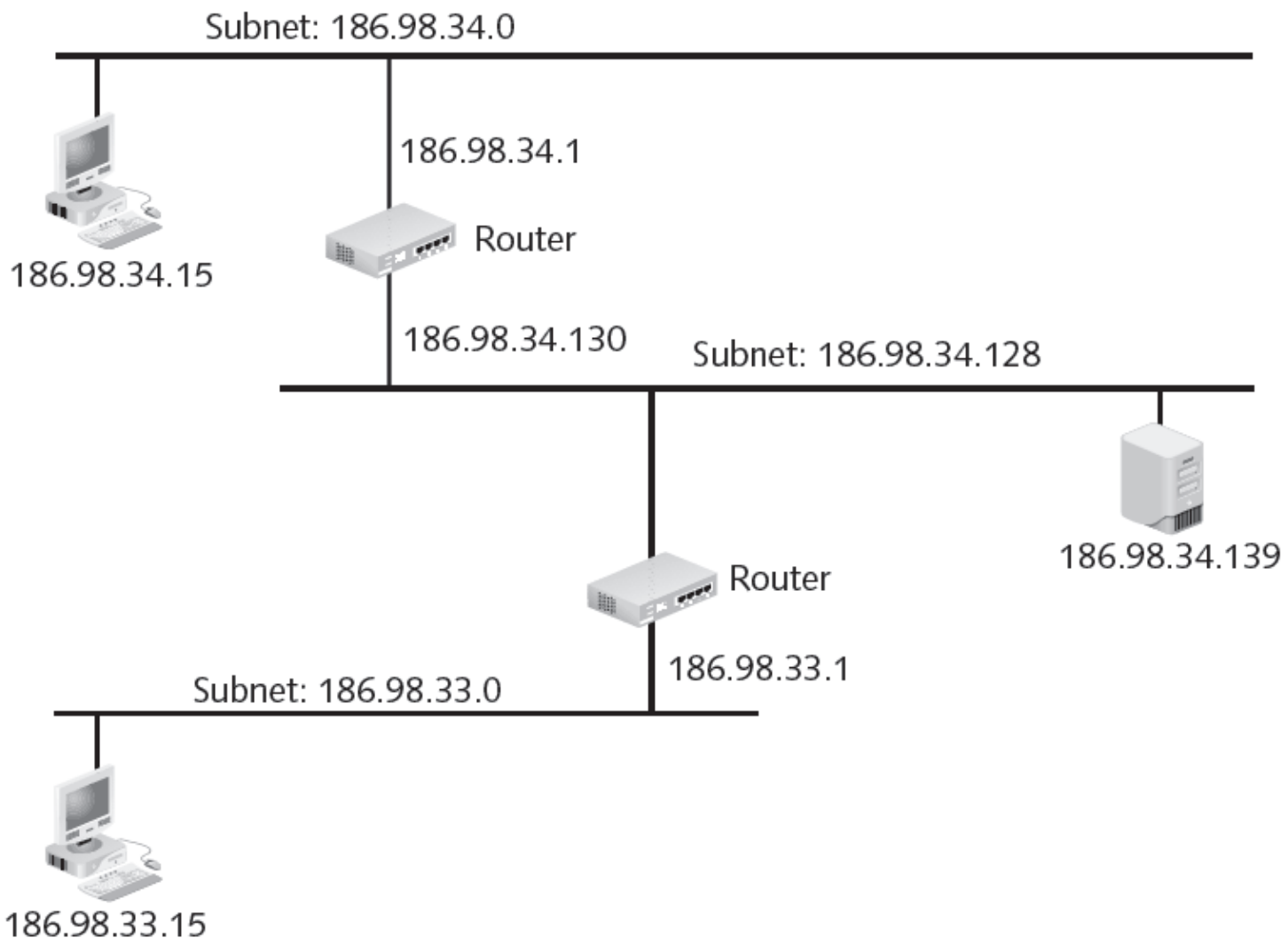
Zone démilitarisée (suite)

- Services fournis à l'extérieur
  - Serveur DNS externe (adresses DMZ seulement)
  - Serveur SMTP
  - Serveur Web
  - Passerelle VPN
- Services fournis à l'intérieur
  - Serveur proxy Web
  - Serveur SMTP
  - Connexion serveur Web et serveur de base de données

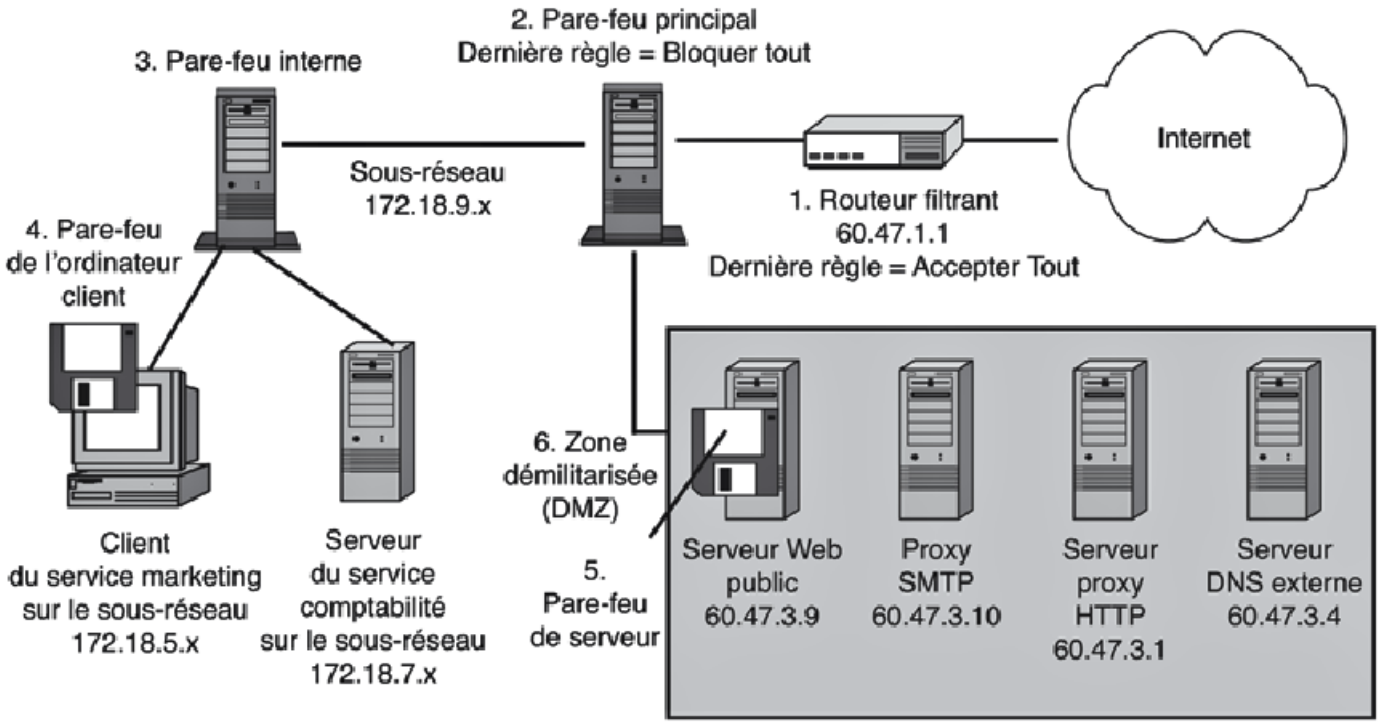
Subnetting

- Les 32 bits d'une adresse IP peuvent être divisés pour représenter
  - Le réseau
  - Le sous-réseau
  - La machine
- Chaque réseau peut contenir plusieurs sous-réseaux
- Chaque sous-réseau contient plusieurs machines
- Avantages
  - Améliorer la sécurité en isolant des groupes de machines
  - Permettre aux administrateurs réseau de cacher la structure interne du réseau

Subnetting (suite)



Vue d'ensemble



Honeypot

- Ordinateur placé dans la zone démilitarisée
  - Contient des informations pour attirer et piéger les pirates
  - Configuré pour avoir des vulnérabilités
- Garde les pirates connectés suffisamment longtemps pour pouvoir les retracer
- Outil de collecte des données sur les attaques et les pirates
- Système d'alerte précoce
- Disponible sous forme
  - Commerciale: KFSensor, NetBait, Specter, etc.
  - Open source: Nepenthes, Valhala, Honeyd, etc.